IEEE Access
Multidisciplinary ⋮ Rapid Review ⋮ Open Access Journal

Received 29 March 2025, accepted 7 April 2025, date of publication 10 April 2025, date of current version 7 May 2025.

Digital Object Identifier 10.1109/ACCESS.2025.3559617

RESEARCH ARTICLE

CIRA-Cyber Intelligent Risk Assessment Methodology for Industrial Internet of Things Based on Machine Learning

GHULAM ABBAS[1], MUSHTAQ ALI[1], MUNEER AHMAD[2], (Senior Member, IEEE), AND AJMAL KHAN[3]

[1]Department of Computer Sciences and IT, Hazara University, Mansehra 21300, Pakistan
[2]Department of Computer Science, University of Roehampton, SW15 5PH London, U.K.
[3]Communication and Information Research Center, Sultan Qaboos University, Muscat 123, Oman

Corresponding authors: Mushtaq Ali (mushtaq@hu.edu.pk) and Ajmal Khan (a.khan1@squ.edu.om)

The authors would like to express their sincere gratitude to the Deanship of Research for funding this project under the project grant titled "DESIGN AND DEVELOPMENT OF DIGITAL TWIN FOR ENHANCED AUTONOMOUS VEHICLE INTERACTION IN A 5G-V2X ENVIRONMENT" (Project Number: IG/DVC/CIRC/25/02). The investigators would also like to thank Sultan Qaboos University for providing a supportive academic environment that facilitated the successful completion of this research.

ABSTRACT The Industrial Internet of Things (IIoT) has transformed the industrial control system to Industry 4.0 and plays an indispensable role in improving the efficiency and productivity of industries. The unique features of the IIoT system have potential innovative models in various industrial fields by providing pervasive communication, fast production, efficient data analytics, and well decision-making systems. As IIoT technologies continue to grow, evolve, and mature, cybersecurity threats and adversarial attacks have also increased, compromising the information security triads, i.e., confidentiality, integrity, and availability within IIoT systems. There is a growing need for cybersecurity awareness and a deeper understanding of cyber threats and vulnerabilities in IoT devices to protect valuable data and information. Risk assessment is a proactive approach to identifying, analyzing, and mitigating potential cybersecurity threats. Implementing intelligent and resilient cyber risk assessment is crucial to taking appropriate security measures to avoid cyber threats before exploiting vulnerabilities and turning them into liabilities for IIoT systems. This research proposes CIRA, an intelligent and resilient cyber risk assessment methodology to identify, assess, and mitigate potential cybersecurity risks using leading machine learning models. To select a suitable machine learning model, centralized and decentralized ML models are applied and compared using a synthetic dataset. The results of extensive trials revealed that the decentralized (federated) machine learning models like FXboost and FSVM outperformed in terms of prediction accuracy by 98%, with a low communication cost of 0.29 MB, a low False Alarm Rate, and excellent performance in the ROC curve. Centralized machine models such as XGBoost and LGBM have a prediction accuracy of 99%, less training time, low FAR, and the best ROC value. The performance of the models is evaluated with the state-of-the-art matrices such as precision, recall, and F.1 score has shown that the centralized ML models are feasible for small to medium datasets, however, Federated Learning techniques are outperformed for medium to large datasets to IIoT systems with safety, security, accuracy, and scalability of IIoT nodes.

INDEX TERMS Industrial Internet of Things, cybersecurity, cyber threats, risk assessment, machine learning, federated learning, cyber threat intelligence, STRIDE threat modeling.

I. INTRODUCTION

The revolution of the Internet of Things (IoT) has significantly transformed human activities across diverse fields, ranging from office to home, entertainment to health, transportation to supply chain, factory floors to marketplaces, and even from submarine to satellite. Statistics show that connected devices are expanding exponentially in this decade. The estimated growth of IoT devices compared to the world population is shown in Figure 1. The number of connected devices is expected to reach 80 billion in 2030 [1]. The industrial control system has also been reformed by

The associate editor coordinating the review of this manuscript and approving it for publication was Wei Ni.

© 2025 The Authors. This work is licensed under a Creative Commons Attribution 4.0 License.
For more information, see https://creativecommons.org/licenses/by/4.0/

this technological revolution and transformed into Industry 4.0 through intelligent and innovative communication processes of the Industrial Internet of Things (IIoT). IIoT enables scalability, advanced analytics, and Industry 4.0 capabilities by integrating cyber-physical systems, aiming at efficient and cost-effective production with flexible workflows and intelligent process coordination. The IIoT architecture can be divided into four layers: data/service layer, application layer, network layer, and sensing layer. These IIoT layers work together to enable efficient, scalable, secure, and interoperable industrial automation [2].

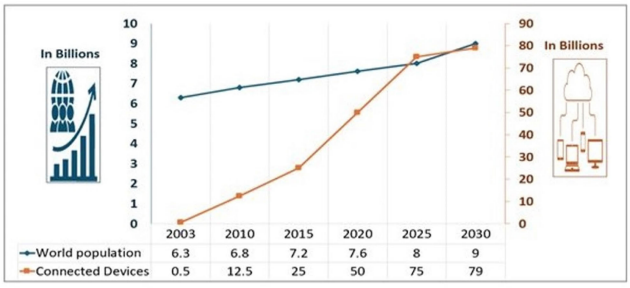


FIGURE 1. Growth trend of Connected Devices (IoT) and the world population [1].

According to a Forbes report, the IoT market is forecast to hit 6 trillion by 2025, which will increase 15% by 2024 [3]. However, with the rapid growth and advances in IIoT systems, cyber threats to these systems have also increased, leading to data breaches, financial losses, operational disruptions, reputational damage, and disruptions to manufacturing processes and supply chains. Kaspersky reported that in the first half of 2024, the number of cybersecurity incidents and data breaches was 30,458 and 10,626, respectively, which is approximately double the figures from 2022. [3].

Cybersecurity threats and their consequences are the most significant barrier to the widespread adoption of the IIoT system [4]. Most cybersecurity attacks target IIoT systems such as transportation, energy, healthcare, and manufacturing, leading to financial losses, operational disruptions, safety risks, and other security challenges [5]. The vulnerabilities of IIoT systems are also being exposed and exploited by cyber threats, including insecure communication protocols, weak device security, delayed patches, lack of network segmentation, and inadequate data encryption. IIoT devices and processes are highly vulnerable to cyberattacks such as Distributed Denial of Service (DDoS), Ransomware, Zero-day attacks, Man-in-the-Middle (MitM), and data breaches [6]. Cybersecurity threats and adversarial attacks on IIoT pose significant risks to individuals, organizations, and society as well. Kaspersky reported that about 64 % global organizations use IoT solutions, but 43 % do not protect them completely [7].

The cybersecurity attack paradigm illustrated in Figure 2 shows that cybersecurity attacks exploit smart devices and systems. An attacker equipped with various cyber attack techniques can exploit an asset's vulnerabilities, leading to potential losses to the IIoT system. To overcome cybersecurity issues and challenges, a holistic and proactive approach of cyber risk assessment is used to identify, assess, and mitigate potential cyber threats [8]. The preliminary steps of the cyber risk assessment process involve identifying and analyzing the assets, vulnerabilities, and associated threats or risks to the system. Cyber threat modeling is a prominent process for identifying and evaluating the possible cyber threats and vulnerabilities of the system. There are several threat modeling techniques and frameworks; however, STRIDE [Spoofing (S), Tampering(T), Repudiation(R), Information Disclosure(I), Denial of service(D), and Elevation of privilege(E)] is one of the most effective and appropriate threat modeling method to identify and assess vulnerabilities [9].

The National Vulnerability Database (NVD) is a US government repository of security-related software vulnerabilities that offers detailed information on the latest vulnerabilities in various application products [10]. It is a valuable resource for organizations and individuals to remain up-to-date and informed about recent potential security risks and to take appropriate measures to defend against cyber threats. NVD provides unique identifiers for each vulnerability through the Common Vulnerabilities and Exposures (CVE) system, making it easier to track specific issues and the corresponding patches. The severity level of the vulnerability is determined using a severity score/level based on the CVSS, which helps in prioritizing and ranking the potential cyber risks [11].

Machine Learning (ML) is inevitable not only to improve business modeling and financial predictions but also to predict cyber threats and assess cyber risks. ML algorithms can be used for precise and automated assessment of cybersecurity risks and their prioritization. Unlike centralized machine learning techniques, Federated Learning(FL) offers a decentralized approach where data is processed on local nodes, thereby minimizing the privacy risks and scalability concerns of node devices in the IIoT system. This approach ensures data privacy and security, as sensitive data is confined to local devices [12]. A detailed comparison of both ML models based on various parameters, such as accuracy, communication cost, and training, is provided in the following section. The proposed methodology CIRA, offers significant advancements over existing approaches by enhancing safety, security, scalability, and accuracy in combating evolving cybersecurity threats. It leverages cyber-intelligent risk assessment techniques, using machine learning-driven threat detection, and real-time monitoring to identify and mitigate potential cyber risks. Additionally, it also ensures robust protection against emerging vulnerabilities by continuously analysing attack patterns and applying security controls. The main contributions of this research are:

- Present a secure, scalable, and resilient environment for industrial IoT systems by identifying, assessing, and mitigating potential cyber risks.

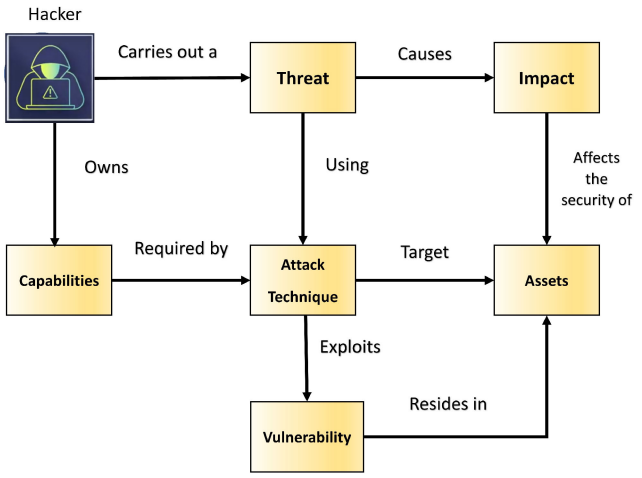


FIGURE 2. Cybersecurity attack paradigm.

- Detailed comparison of centralized and decentralized (federated) machine learning models, providing insights into the strengths and weaknesses of both learning techniques for cyber risk assessment of industrial IoT.
- Implement the proposed methodology in the case of Energy Management System through thorough discussion on its smart devices, security vulnerabilities, possible threats, and control measures.
- Reduce attack surfaces by evaluating the security vulnerabilities of IIoT devices using NVD, CVE, and CVSS metrics.

The composition of the paper is outlined as follows: Section II describes the most relevant research work on the topic. Section III presents the concept, definition, and process of cybersecurity risk assessment. Section IV discusses the proposed methodology, Section V presents the results, Section VI discusses the results and discussions, and Section VII presents the conclusion.

II. RELATED WORKS

Numerous authors have addressed cybersecurity risk assessment techniques in their research and proposed their approaches toward the prediction of cyber threats to the IoT system. This section discusses the contributions and limitations of the selected papers.

Kalinin et al. [13] presented a quantitative methodology to assess the risk assessment of cyber threats in smart city environments based on data mining and object typing. They categorized cybersecurity risks into passive attacks and active attacks. In a passive attack, a hacker attempts to gain unauthorized access to sensitive data and information without disrupting the system's normal functioning. These types of attacks often exploit the weaknesses in systems through vulnerabilities to gain sensitive data and gather information for further malicious activities of the system, such as data repositories, communication networks, and control of the systems. On the other hand, active attacks involve gaining unauthorized access by a hacker to manipulate data and information, disrupt operational activities, or cause damage to the system. The attacker uses various techniques, such as social engineering, hacking, DoS attacks, or malware, to compromise the security of a smart city's information systems. A detailed discussion on the different attacks like DoS, DDoS, Black Hole, Grey hole, Sinkhole, Wormhole, and Sybil, which may be harmful to the IIoT, especially on smart home systems. The authors presented a Perceptron model and a back-propagation algorithm of ANN to identify and calculate the risk of the mentioned attacks. The algorithm is used to process and simulate cybersecurity datasets. The simulations contain 10,000 vectors and 28 features each for device type, device cost, and the possibility of specific cyber attacks. The accuracy of the proposed model was 97%. Moreover, they claimed that machine learning techniques play a crucial role in cybersecurity risk assessment, where large amounts of data and their dependencies are involved.

In [14], Flores et al. presented a risk assessment methodology using the Bayesian Networks for smart home-based IoT systems. The authors employed the Bayesian Network in the risk assessment of the smart home environment. The attack graph is used to construct the Bayesian network, and the probability values are derived from Bayesian inference. The risk impact is calculated by the multi-criteria assessment method and the assessment scoring values range from 0 to 100. CVSS (Common Vulnerability Scoring System) metrics were used to calculate the vulnerability in the network. The proposed risk assessment approach is applied to a limited attack vector of Denial of Service (DoS) and Man-in-the-Middle (MiTM).

Kieras et al. [15] proposed a novel framework for supply chain risk assessment and mitigation of IoT systems using the Birnbaum Structural method. The proposed model measures the risk analysis as well as evaluates the budget-constrained optimization and approximation of supplier choice issues by prioritizing the risk as per the organization's needs. They described the supply chain risk as coincident with the entire critical infrastructure, and cyber threats in supply chain are robust.

Kandasamy et al. [16] presented a comparison of four leading risk assessment methodologies i.e. NIST (National Institute of Standards and Technology), TARA(Threat Assessment & Remediation Analysis), OCTAVE(Operationally Critical Threat, Asset and Vulnerability Evaluation), and International Standards Organization (ISO). They presented a use case study of IoMT for risk assessment with a risk scoring system and risk vector categorization (low, medium, or high). A quantitative risk assessment using this framework for the limited risk domain is used. In this study, the authors have not mentioned any proper techniques to analyze the vulnerability associated with the IoMT devices.

A combinatorial vulnerability-based assessment of IoT leverages Industry 4.0 using the randomized algorithm by George and Thampi in [17]. The authors used a penetration graph for the detection of vulnerabilities and the removal of

the attack path from the network. They proposed a linear programming approach to find out the main attack path.

Arat and Akleylek in [18], presented a risk and vulnerability assessment methodology for the IIoT environment. Graph theory is used to develop the attack tree for the detection of the attack vector, and NVD is used for the vulnerability of the devices used in the network. The authors used the Floyd-Warshal algorithm to find the risk level of the system. They used a use case of the transportation system to validate the methodology.

Abbass et al. at [19] proposed a Deep Learning algorithm to classify the security risks of IoT systems. The Convolutional Neural Network (CNN) algorithm uses PyTorch to efficiently assess the potential cybersecurity risk. Flores et al. [14] presented an intelligent cybersecurity risk management for an IoT-enabled smart manufacturing system. They applied FAHP (Fuzzy Analytical Hierarchical Process), which has multiple criteria and decision-making techniques to compute the potential security risk factors, i.e., likelihood and impact consequences. The proposed risk management model has three tiers, i.e., (1) data collection, (2) FAHP, and (3) strategy formulation. The authors also included the research findings on the analysis and implications of FAHP.

In [20], the authors presented vulnerability and risk assessment methods to resolve cybersecurity issues in IoT-based networks. The authors used varying procedures and methods of graphical threat models to identify the attack, assess risk levels, and detect the attack paths. The research study aims to provide a generic and viable solution for the vulnerability assessment of IoT-based networks through a graphical structure. A smart home scenario use case is used to evaluate and implement the proposed idea.

In [21], Razavi et al. used Large Language Models (LLMs) alongside Deep Learning, SVM, and Random Walk models to estimate the financial impact of cyber threats. They highlight the financial consequences of cyber incidents, underscoring the need for robust cybersecurity measures and risk mitigation strategies.

The comparative literature review summarized in Table 1 highlights the different and diverse methodologies employed in cybersecurity risk assessment, focusing on attack path detection, threat modelling, vulnerability assessment, empirical validation, and security controls. While traditional approaches, such as Bayesian Networks, CNN, and randomized algorithms, have been widely used, recent studies leverage LLMs and Deep Learning for estimating financial impacts. However, the proposed CIRA framework stands out by integrating Machine Learning and Federated Learning, offering a more comprehensive approach for cybersecurity risk assessment IIoT systems. CIRA provides a holistic methodology, incorporating real-world empirical data, security controls, and risk mitigation strategies.

III. CYBER SECURITY RISK ASSESSMENT PROCESS

Cybersecurity risk assessment is a vital and proactive process to ensure the cybersecurity of any information system. It helps to identify and assess the security vulnerabilities of a system and predict the associated cybersecurity threats. The process involves evaluating the likelihood of security breaches, presenting the severity levels, and strategies to mitigate cybersecurity risks [22]. The risk assessment process is ongoing to stay ahead of evolving potential cyber risks and maintain robust security postures for long-term success. [23]

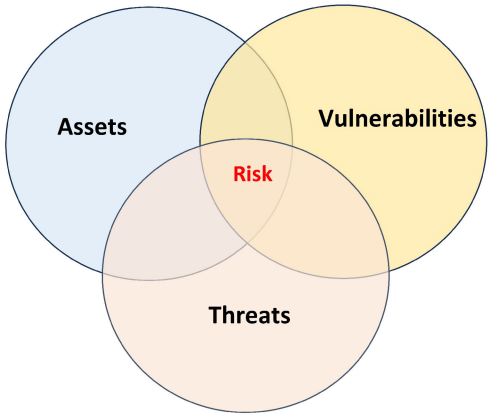


FIGURE 3. Risk, Assets, Vulnerabilities, and Threats.

Cybersecurity risk is the combination of assets, vulnerabilities, and associated threats to a system, which is shown in Figure 3. Institute of Risk Management (RIM) defined that a risk may be physical damage, financial or reputational loss to an organization from failure of its information or operational systems [24]. The impact of risk of a system can be calculated by the asset value, its vulnerability, and the impact of associated threats by the following formula [25]:

$$\text{Risk} = \text{Asset} \times \text{Vunlerablity} \times \text{Threat} \quad (1)$$

There are two types of cybersecurity risk assessment i.e. Quantitative and Qualitative. In qualitative risk assessment, analysis of the system is undertaken by experts through questionnaires, checklists, and rating estimates. However, in the Quantitative risk assessment, the risk may be analyzed through analytic, probabilistic theories, and predictions through intelligent techniques [26], [27].

An important activity in the cyber risk process is the cyber risk rating, which is a structured method to quantify the level of risk. This rating process provides a measurable rank or score that helps stakeholders to understand the severity level of the risk for decision making toward control and mitigation of the potential threats. The risk rating can be classified as a score ranging from 0.1 to 1.0. The rank may be presented in different colors as Insignificant, Low, Medium, High, and Critical, as shown in Table 2. [28].

IV. CIRA-METHODOLOGY FOR CYBER SECURITY RISK ASSESSMENT

The proposed methodology CIRA aims to identify, assess, and mitigate the potential cybersecurity risk by identifying the vulnerabilities and associated threats to the industrial

TABLE 1. Summarize literature reviews.

Author	TopicDiscussion	model/ algorithm used	attack path detection	Threat Modelling	VulnerabilityAssessment	Empirical data &Experiment	Consequences& security controls
Kalinin M. et al. [13]	Quantitative Assessment of cyber security risk in smart city	perceptron model and back-propagation algorithm	×	×	✓	✓	×
Flores M. et al. [14]	IoT Risk assessment based on Bayesian Network for smart home	Bayesian Networks	✓	×	✓	✓	×
Kieras T. et al. [15]	framework for risk analysis and mitigation of supply chain system	No. Model used	✓	×	×	✓	×
Kandasamy K et al. [16]	Quantitative Risk Assessment Framework	Construction Disputes Based	✓	×	✓	✓	×
George G. et al. [17]	vulnerability based risk assessment of IIoT	randomized algorithm	✓	×	✓	✓	×
Arat F. et al. [18]	Attack path detection	Deapth First Search and Floyd Marshal Algorithm	✓	×	✓	✓	×
Wissam A. et al. [19]	Security Risk Assessment	CNN	✓	×	✓	✓	×
George G. et al. [20]	Vulnerablity based -attack towards edge devices	graphical models and Bayesian network	×	×	✓	✓	×
Razavi, H. et al. [21]	Estimating the financial impact of cyber threats using LLMs	LLMs, Deep Learning, Support Vector Machines	×	×	×	✓	×
The proposed work -CIRA	Cyber Risk Assesment of IIoT system	Machine learning & Federated Learning	✓	✓	✓	✓	✓

TABLE 2. Risk categorization and severity levels.

Qualitative Risk Level	Quantitative Risk Weightage (W)	Risk Score (S)	Color presentation	Description
Very High	96–100	1.0		Critical condition of risk with high concern and has severe impact
High	80–95	0.8		Cyber risk with high concern and need attention
Medium	31–79	0.5		Cyber risk of moderate concern
Low	11–30	0.2		Cyber Risk of low concern
Very Low	0–10	0.1		Insignificant cyber risk and has no concern

Internet of Things. The methodology provides security controls to mitigate cybersecurity risk, which reduces financial losses and reputational damages of any industrial system. The process and risk assessment techniques of the proposed methodology are according to the guidelines provided in the standards ISO 31000:2018, ISO 31010:2009, ISO/IEC Guide 51:2014, and ISO/IEC 27005:201. Figure 4 illustrates the architectural diagram of the proposed model. The proposed approach is divided into four phases: analytical scope, model generation & risk estimation, visualization & reporting, and security controls. Each phase is discussed in the following section, and the CIRA approach is applied to a use case of a smart energy management system.

Phase I: Analytical scope: This phase defines the context and scope of cyber risk requirements, including the declaration of critical assets, vulnerability assessment, and threat modeling. Identify critical assets such as devices, data, and processes used in Industrial IoT and use historical data and records of vulnerabilities and exposures as input to predict cyber risks. For this purpose, use CVEs of each vulnerability from the NVD as input for vulnerability exposure. Focus on three fields of each CVE: the text field describes the vulnerability exposure, type, and the base score value describes the severity level of the device. The STRIDE threat modeling framework is used to identify and categorize the potential cybersecurity threats to the IIoT system.

Phase II: Model Generation and Risk Estimation: After the analytical scope, the next step is data pre-processing and deployment of machine learning algorithms to predict, assess, and prioritize cyber security risks of Industrial IoT. Both centralized and decentralized algorithms are presented in Algorithm 1 and Algorithm 2. The selection for comparison of machine learning models like XGBoost for its efficiency and high performance in handling imbalanced cybersecurity datasets, SVM for its robustness in anomaly detection, and FedXGBoost for its ability to leverage federated

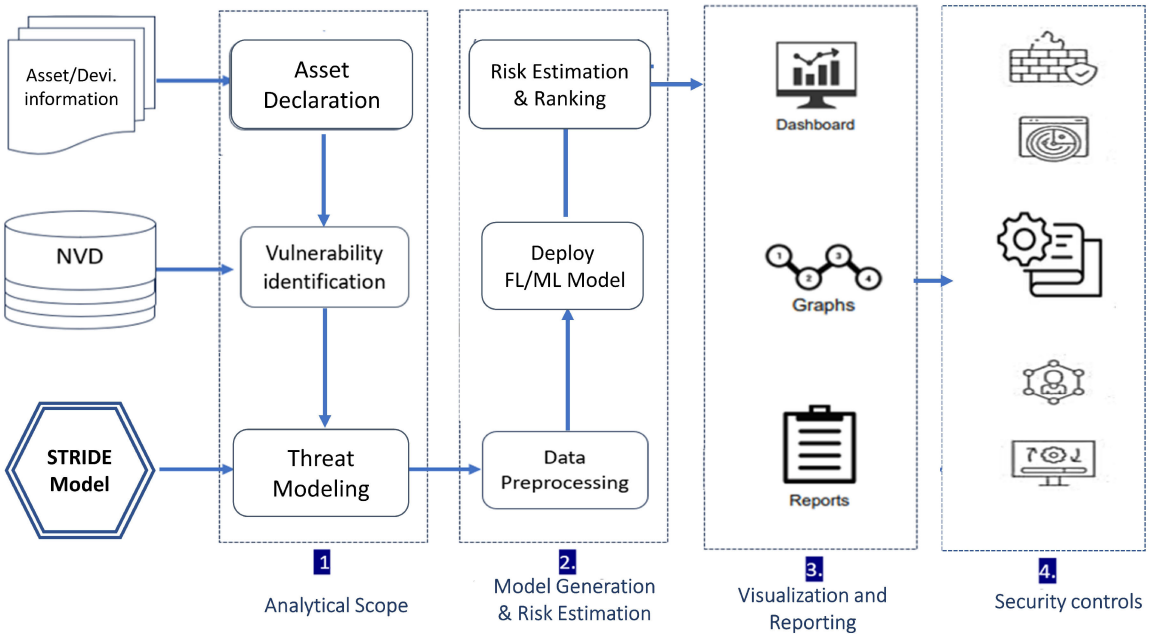


FIGURE 4. CIRA-Architecture diagram.

learning while maintaining strong predictive accuracy. The implementation and comparison of selected centralized and decentralized (federated) ML models are presented in the following section.

Phase III: Visualization and Reporting: Representation and reporting are an important part of any process to present the outcomes. In this phase, visualize the details of the cybersecurity risk by depicting the graph, charts, and reports on ranking and prioritizing the cybersecurity risks of the IIoT system.

Phase IV: Security Controls: The last and important part of the proposed CIRA methodology is to suggest and apply the security controls for potential risks. A list of security controls, as indicated in Table 6, is proposed for the use case of the Smart Energy Management System.

A. USE CASE: SMART ENERGY MANAGEMENT SYSTEM-SCENARIO

This section presents a use case scenario of a smart energy management system (SEMS) for easy understanding of the proposed CIRA methodology. The architectural model of the SEMS is shown in Figure 5. The smart energy management system is an example of an IIoT-enabled scenario that provides ease and convenience for users to interact, control, and monitor connected smart devices. SEMS provides efficient and intelligent services to users that improve efficiency and performance compared to a traditional energy management system [28]. On the other hand, there are many challenges like safety, security, and energy of such resource-constrained and limited devices [29]. The proposed CIRA approach will help to overcome cybersecurity threats and challenges through intelligent and resilient risk assessment and security controls.

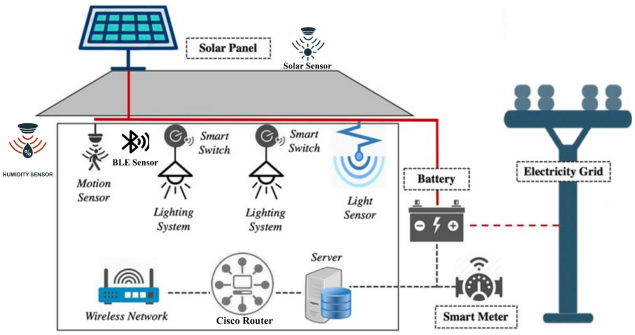


FIGURE 5. Overview of smart energy management system.

The devices used in the SEMS use case are Raspberry Pi Model 3B gateways, i-REAP, BLE Sensors, solar sensor (SI V -10-TC), Wind sensor, TerOpta, outdoor temperature and relative humidity sensor (RH-632), Tesla Powerwall II, Emporia Vue III, energy and building control units, Cisco 809 Industrial Integrated Services Routers (ISRs) and CISCO router IR1101.

The analytical scope of the IoT devices used in SEMS and details of the known vulnerability and the CVSS score are listed in Table 3. The table contains three fields, i.e., CVE-ID, device description, and base CVSS score of the particular device. Each CVE has two information fields of vulnerability number and exposure year. The SEMS have different types of smart devices and known vulnerabilities, which encompass a base score (CVSS) between 0 and 10, used to determine the impact on the overall systems and individual user actions. The CVSS scores help to prioritize the vulnerabilities based on their potential impact, allowing

TABLE 3. SEMS Vulnerabilities with CVSS score.

CVE- ID	Device	CVSS (base score)
CVE-2020-15505	Schneider Electric Modicon PLCs	7.5
CVE-2021-31073	Rockwell Automation ControlLogix	8.1
CVE-2022-29499	Axioma IIoT Platform	9.0
CVE-2019-14745	Siemens S7-1200 PLCs	6.5
CVE-2023-23980	IIoT network devices	6.8
CVE-2023-28743	IP Camera	6.6
CVE-2021-14402	Terminal controller	3.2
CVE-2019-0739	Sensor controller	4.1
CVE-2023-4312	Mail server	5.9
CVE-2022-47974	BLE Sensor	6.5
CVE-2021-1441	CISCO router IR1101	6.7
CVE-2020-3198	Cisco ISRs 809	9.8

for more effective risk assessment in energy management systems. Regular monitoring and timely remediation of cybersecurity threats are crucial to maintaining the safety and security of the system.

For instance, in the first row of Table 3, CVE-2020-15505 is a vulnerability exposure of a device, Schneider Electric Modicon PLC used in SEMS. The CVSS base score of this device is 7.5, which is a high-risk level. Another vulnerability exposure CVE- 2019-14745 of Siemens S7-1200 PLCs has a CVSS base score of 6.5, considered a medium risk level. Similarly, in another device Terminal controller CVE-2019-14402, the base score of the CVSS value is 3.3, which is considered a low severity level.

Table 4 shows the list of known vulnerabilities and threats associated with the device in the SEMS. The list describes the vulnerability types and CVEs of attack surfaces where an unauthorized user may access the SEMS. The list also described the STRIDE category of each vulnerability. For instance, devices in SEMS have inadequate and poor physical security as vulnerability V-1, which may be exploited the system by a number of threats having CVEs like CVE-2021-32934, CVE-2018-18852,CVE-2017-12741, CVE-2020-25175, and CVE-2022-45788. The Tempering (T) and Spoofing (S) category of STRIDE is involved in vulnerability V-1. Similarly, other vulnerabilities are exploited by associated threats having unique CVEs with the STRIDE category as mentioned in the table.

As discussed, STRIDE threat modeling is used to identify and address the potential cybersecurity threats in any cyber-physical system. By addressing the specific security threats outlined in STRIDE, organizations can help ensure the security triad integrity, confidentiality, and availability of their energy management systems, and protect against potential cyber-attacks [30]. Categorization and application of the STRIDE threat model in the SEMS with a few examples are:

- **Spoofing**: Attackers could impersonate the smart devices by sending false data. For example, a malicious actor might spoof the identity of a smart meter and report false energy consumption data to the central system, resulting in financial losses or incorrect billing. Implement robust authentication mechanisms such as multi-factor authentication to mitigate spoofing. V-1, V4, V11, V-17, V-18, etc of Table 4 fall into the Spoofing category.
- **Tampering**: Attackers might alter the energy data or system settings. For example, a hacker might modify or change the data sent from a smart thermostat to the energy management system to falsely report a higher energy consumption than actual, causing overcharging or triggering unnecessary power-saving measures. Encryption, physical security, and integrity checks are the mitigation strategies and controls. In Table 4, vulnerability V-1, V-3, V-5, V-6, etc, fall in the Tempering (T) category of STRIDE.
- **Repudiation**: Users might modify the settings or data, such as changing energy settings or turning off a system, leading to a lack of accountability. For example, a user might alter the energy settings of the system to save mone,y which makes it difficult for the system to track energy use correctly. Audit logs, digital signatures, and non-repudiation protocols are used to mitigate the issue. V-2 and V-21 of Table 4 fall in the category of Repudiation (R) of the STRIDE model.
- **Information Disclosure**: Sensitive data, such as energy usage, could be exposed to unauthorized users, which leads to privacy violations or exploitation of vulnerabilities. For example, a hacker might interrupt communications between smart meters and the central system (server) and take sensitive data like household energy consumption patterns, which may be used for targeted attacks and exploitation. To mitigate these security issues, data encryption, secure protocols, and access control are used. V-8 V9, V-10, V-12, V-14, etc of Table 4 fall in the category of Information Disclosure (I) of the STRIDE model.
- **Denial of Service (DoS):** The attacks could launch a DoS attack and disrupt energy management operations or cause power outages. For example, flooding of repeated requests to the central SEMS system might unable to proceeding with services to the legitimate user. Intrusion detection and prevention systems, rate limiting, and fail-over mechanisms are used to mitigate the DoS security issues. V-3 V-6, V-18, V-22 etc of

TABLE 4. List of known vulnerabilities.

Vul. #	Description	Comm. vulnerability. Exposures (CVEs)	STRIDE
V-1.	Inadequate and poor physical security	CVE-2021-32934 CVE-2018-18852 CVE-2017-12741 CVE-2020-25175 CVE-2022-45788	T, S
V-2.	No energy harvesting	CVE-2019-10915 CVE-2018-14805 CVE-2020-25175	D,R
V-3.	Open de-bugging ports	CVE-2020-25175 CVE-2021-32934 CVE-2020-28212	E, T
V-4.	Poor credential (password)	CVE-2021-32934 CVE-2017-12741 CVE-2020-25175 CVE-2020-28212	S, E
V-5.	Weak boot process	CVE-2020-28212 CVE-2020-25175 CVE-2017-12741 CVE-2018-14805	T, E
V-6.	losses Availability	CVE-2021-34398, CVE-2020-12826	D
V-7	Encryption improper	CVE-2023-24318, CVE-2020-38983	I, T
V-8	Improper and insufficient patch management	CVE-2020-28212 CVE-2017-12741 CVE-2021-32934 CVE-2020-25175	I, T
V-9.	Network services insecure	CVE-2020-25175 CVE-2021-32934 CVE-2017-12741 CVE-2020-28212 CVE-2018-14805	T, I
V-10.	Ecosystem interfaces insecure	CVE-2020-25175 CVE-2021-32934 CVE-2018-14805 CVE-2017-12741 CVE-2020-28212	T, I
V-11.	Weak authorization or authentication	CVE-2021-32934 CVE-2020-25074 CVE-2019-0701 CVE-2018-14805 CVE-2020-28212	S,E
V-12.	Cloud interface insecure	CVE-2020-25175 CVE-2021-32934 CVE-2018-14805 CVE-2020-28212	I,T
V-13.	Missing of authorization	CVE-2020-10942 CVE-2021-33223 CVE-2018-14805 CVE-2020-28212	E
V-14.	Un-encrypted services	CVE-2020-25626 CVE-2021-34746 CVE-2021-3122	I
V-15.	Attackers of MiTM	CVE-2019-4000	I,T
V-16.	Permitting Attackers to Execute Unauthorized Commands	CVE-2019-5638	E
V-17.	Un-authenticated remote attacker	CVE-2018-7445	S,E
V-18.	Attackers prevent the authorized users to monitor the BGP	CVE-2020-0605	D
V-19.	Un-authenticated pairing with both LE Secure Connections	CVE-2021-34746	S,I
V-20.	Allow un-trusted user to access the Bluetooth application and information.	CVE-2021-32648	I,T
V-21.	Zero day vulnerability	CVE-2020-15505, CVE-2018-15473	S,R
V-22.	DOS attack to drain the sensor battery	CVE-2022-26143,CVE-2017-7670	D
V-23.	Inject false data disrupt the process chain	CVE-2019-5638, CVE-2020-45901	I, T
V-24.	Im-proper access control vulnerability	CVE-2020-3452 , CVE-2020-5902	E
V-25	security vulnerability(Blue Borne)	CVE-2020-14315	E, T
V-26	Information disclosure	CVE-2019-0786	I
V-27	Bluetooth hack	CVE-2020-5383	T,I
V-28	Bluetooth data leak (protocol)	CVE-2021-29531	T,I
V-29	Predictable Auth Value in Bluetooth Mesh Profile provisioning	CVE-2020-26558	S, T
V-30	Bluetooth Mesh Profile Auth Value leak	CVE-2021-26551	I
V-31	Fake attack in Bluetooth Mesh network Profile	CVE-2021-22972, CVE-2020-06012	S,T
V-32	Fake BR/EDR pin-pairing protocol	CVE-2021-26555	S,T
V-33	Impersonation in the BR/EDR (Basic Rate/Enhanced Data Rate) pin-pairing protocol	CVE-2021-16555	S
V-34	Attacker gain complete access control of the device via high privileges of the Bluetooth stack access	CVE-2018-12315	E,T
V-35	Gateway fails to verify the communication channel ownership.	CVE-2020-9019	S,T
V-36	Device-Internal Network Port Improperly Accessible from External Networks.	CVE-2021-22919	T, I
V-37	allows remote attackers to gather information about the file system structure.	CVE-2019-11602	S, T
V-38	allows an attacker to impersonate	CVE-2020-20372, CVE-2019-8479	S, T
V-39	Remote attackers allow to bypass security access controls	CVE-2018-0801, CVE-2020-4729	ET
V-40	Allow an unauthenticated remote attacker to retrieve sensitive information.	CVE-2020-01653	I

Table 4 fall in the category of DoS (D) of the STRIDE model.

- **Elevation of Privilege**: An attacker or hacker can exploit a vulnerability and gain administrative access to

control to escalate their privileges or alter the energy management system. For example, when a user account exploits a vulnerability in the SEMS, the attacker could alter the energy settings, delete data, and disrupt the system's operations. Least privilege enforcement, regular patching, and access monitoring methods are used to control these security issues. V-4, V-5, V-11, V-13, etc of Table 4 fall in the category of Elevation of Privilege (E) of the STRIDE model.

The STRIDE threat modeling helps to identify and address potential security risks in SEMS by focusing on device authentication, access control, data integrity, and system availability by ensuring the SEMS system is secure and resilient to cyber threats.

Algorithm 1 Centralized Machine Learning for Cyber-Risk Assessment of IIoT System

INPUT: `data_frames, labels, size`
OUTPUT: Trained model

```
for each df in data_frames do
    X,Y = Preprocess_data(df,labels)
end for
Merge(data_frames)
X_train, X_test,Y_train,Y_test=Split(X,Y,
0.8)
scaler = Standardize(X_train)
X_train, X_test = Transform(scaler,
    X_train, X_test)
Xt_balanced,Yt_balanced = Apply STIRDE &
Resampling(X_train, Y_train)
model = DefineMLArchitecture()
Compile(model)
for Xt_balanced,Yt_balanced,X_test,Y_test do
    history = Train(model, Xt_balanced,
     Yt_balanced,X_test, Y_test,labels,
     epochs,batch_size)
    device_features=get_device_features
     (device)
     risk_level = model.predict(device
     _features)
end for
Evaluate the cyber risk of IIoT device.
```

B. SYNTHETIC DATASET

A synthetic dataset SecRiskAI has been retrieved from Kaggle, which covered the cybersecurity issues related to IIoT devices, known device vulnerabilities, and security threats to the IIoT system [31]. The dataset is used to analysis patterns, trends, and insight into the security risk assessment. It contains 09 attributes and 100,000 records. In the following section, the latest machine learning models of both centralized and decentralized (federated) algorithms are used to compare for cyber security risk assessment of IIoT systems.

Machine Learning Algorithm:

The algorithms aim to assess and quantify the cybersecurity risks of the IIoT system. Algorithm **1** for centralized machine learning, input data along with the labels, is preprocessed individually and merged into a single dataset.

Algorithm-2 developed for decentralized (Federated) machine learning, input data with the labels preprocessed individually and merged into a single dataset. The Federated Learning (FL) involves collaborative learning across the distributed nodes keeping data localized. The local model is trained and the updates are aggregated centrally. The overall objective function F(w) are:

$$min.F(w) = \sum_{i=1}^{N} [\frac{ni}{n}] Fi(w) \tag{2}$$

where $\boldsymbol{w}$ is the global parameter, $\mathbf{F}(w)$ is the overall objective function, $\mathbf{F}i(w)$ is the global loss function for node i , $\mathbf{N}$ is the number of IIoT devices or nodes, n_is is the number of data samples on node $\boldsymbol{i}$.

The FL algorithm combines the local model to produce the global model by the following formula:

$$W_{t+1} = \sum_{i=1}^{N} [\frac{ni}{n}] w_{i,t+1} \tag{3}$$

where W_i, $(t+1)$ is the updated weights from node $\boldsymbol{i}$ at round $\boldsymbol{t+1}$, and $W_(t+1)$ is the aggregated wights of global model.

Algorithm 2 Federated Machine Learning (Decentralized) for Cybersecurity Risk Assessment of IIoT System

Require: `data_frames, X,Y,epochs, labels, w, N training_round N`

```
Initialize global model w
g= DefineFLArchitecture()
Compile the global model g
for i = 1, 2, ..., N do
S_i ← Subset of selected devices
for each device j in S_i do
    X,Y=Preprocess_data(data_frames[j], labels)
    X_train,X_test,Y_train,Y_test=Split
     X,Y,0.8)
    scaler = Standardize(X_train)
    X_train,X_test = Transform
     scaler,X_train,X_test)
    X_i_balanced, Y_i_balanced ←
     Apply STIRDE & Resampling(X_train,
     Y_train)
     Local model m=Clone of global model g
    Train(m, X_i_balanced, Y_i_balanced, X_test,
     Y_test, labels, epochs, batch_size)
    device_features=get_device_features
     device) risk_level = model.predict(device_features)
     Aggregate weights of m to w
end for
Update the global model g
Save global model w
Evaluate the cyber risk of IIoT devices.
```

C. RISK RANKING

After the assessment and calculation of cyber risks, the next step is to quantify the level of risk of the possible threat to IIoT devices. It will help to sensitize the potential cyber threats

TABLE 5. Use Case: SEMS risk level calculation.

Device type	Vulnerability	CIA Impact (imp)	Exploitability (exp)	Device risk factor (drf)	Likelihood (lik)=(exp+drf)/2	Risk score = Imp*lik	Risk
Gateway based on Raspberry Pi Model 3B+	Does not exactly verify ownership of the [illegible] channel	6.41	10.0	7.50	8.750	56	
	Denial of Service (DoS)Overflow	10.0	3.91	7.21	5.56	56	
	Allow un-authenticated remote user	2.91	8.61	4.31	6.46	19	
	Allow Code Execution	10.0	10.0	10.0	10.0	100	
	Spamming attack	2.91	10.0	5	7.51	22	
	DoS on a device	10.0	3.91	7.12	5.56	57	
	access physical security vulnerability	10.0	3.91	7.12	9.25	93	
Bluetooth Low Energy (BLE) Sensors	enables an attacker to access user line CLI(command line interface)	10.0	8.0	9.0	8.51	86	
	Allows to execute arbitrary code to remote hackers	6.41	6.51	5.81	6.25	39	
TerOpta GEM energy monitoring and control units	allow an un-authenticated access	2.9	10	5	7.5	22	
	vulnerable remote code execution	10.0	10.0	10.0	10.0	100	
	Allows attacker to perform a MITM (Man-in-Middle) attack	5.91	1.61	7.51	4.56	29	
	An attacker may use the overflow to gain full access and control	10.0	5.51	7.91	6.71	67	
Wind sensor	D.o.S	2.91	10.0	5.1	7.51	23	
Solar ir-radiance sensor (SIs -V-10TC)	Unauthorized remote user to privileges and execute the arbitrary code	10.0	10.0	10.0	10.0	100	
	allows remote attackers to execute arbitrary code	10.0	10.0	10.0	10.0	100	
Outdoor wired temperature and humidity sensor (RH6-32)	Gives the attacker control over the data that is written into this double-memory allocation	5.91	1.81	7.81	4.81	29	
Cisco IR1101 Rugged Router	Allow an authenticated to access but low-privileged	10	3.91	7.21	7.51	75	
	Un-authenticated hacker with physical access to the device	5.21	0.91	6.11	3.51	19	
	Allowing an hacker with Administrative privileges to access and login credentials	5.21	0.31	5.51	5.56	28	

and controls to mitigate the impact of the attack on the IIoT system. Table 5 presents the details about the likelihood and risk score of the known vulnerability of the devices used in SEMS with color presentation as categorized in Table 2.

D. REDUCTION OF ATTACK SURFACE

Two steps involve in reducing the attack surfaces or points where the threats may exploit the vulnerabilities of the SEMS. The first step involves, assessing and evaluating vulnerabilities of the IIoT devices used in the SEMS, as shown in Table 4 having vulnerability descriptions and CVEs against each vulnerability. Secondly, it is important to identify security controls to patch the respective vulnerabilities and control possible attacks. Security controls are used to mitigate the security threat by reducing the attack surfaces as shown in Tables 6 and 7. The CIA impact (imp), exploitability (Exp), and device risk factor (drf) of each vulnerability of devices used in the SEMS are tabulated in Table 5. It presents how to calculate the risk level of the devices used in the SEMS. The impact of the likelihood of the threat can be calculated by the following formula:

$$Likelihood = (exp + drf)/2 \tag{4}$$

and risk score can be calculated as:

$$RiskScore = Impact \times likelihoond \tag{5}$$

The detail about the risk score and color presentations as presented in the Table 1, apply in the risk level calculation of use case SEMS in Table 5. As mentioned in the preceding section, if the risk score falls in the category of the high-concern and needs mitigation then apply the respective security controls. For example, the risk rank is calculated as 10, placing it in the very low-risk category, and therefore it is not deemed significant enough to warrant consideration. Similarly, if the risk score calculated is 50, falling in the medium risk level, it should be considered for mitigation. If the risk score calculated is 98, falling in the very risk level, it needs better treatment and security controls as its impact is very high.

E. SECURITY CONTROLS

Table 6 presents the possible security controls and Table 7 demonstrates attack surface reduction by patching vulnerabilities and security controls. Apply the security controls against the attack surface/points at different network layers of the use case to mitigate cyber risk.

V. RESULTS

Based on the dataset, the results of the centralized and distributed (federated) machine learning models are shown in Figures 6, 7,8, 9, and 10. Figure 6 illustrates the accuracy of the risk prediction of selected centralized and distributed (federated) machine learning models. The results indicated that the XGBoost model performs well with an accuracy of almost 99%, and the prediction accuracy rate of federated ML models FedXGboost is 98%. Figure 7 presents another important factor of the training time of the selected machine learning models. The results show that centralized machine models like SVM and KNN have a minimum training time to complete the risk assessment process.

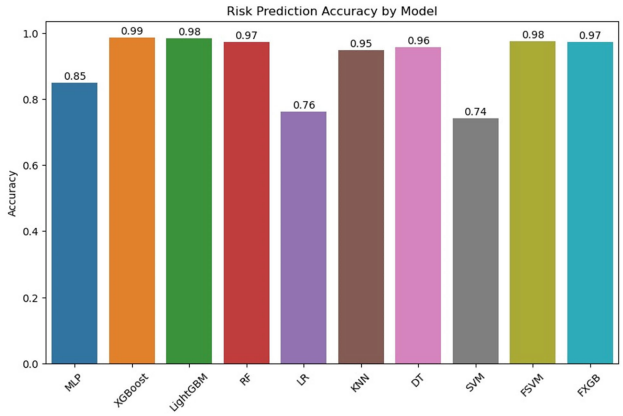


FIGURE 6. Risk prediction accuracy of centralized and federated Models.

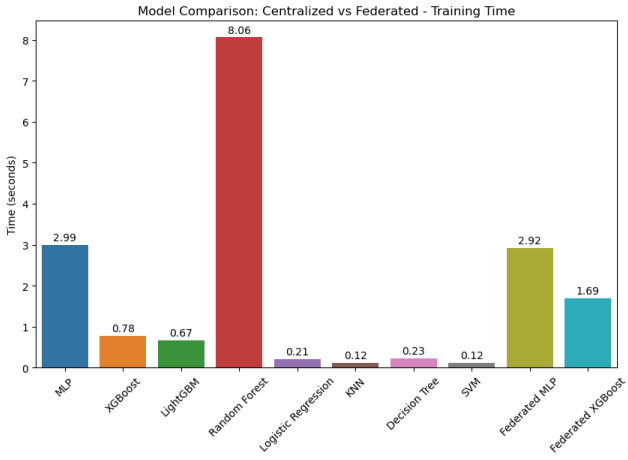


FIGURE 7. Training time comparison of centralized and federated learning Models.

Figure 8 illustrates the false alarm rate (FAR) of the selected ML models. The FAR is a metric used in numerous

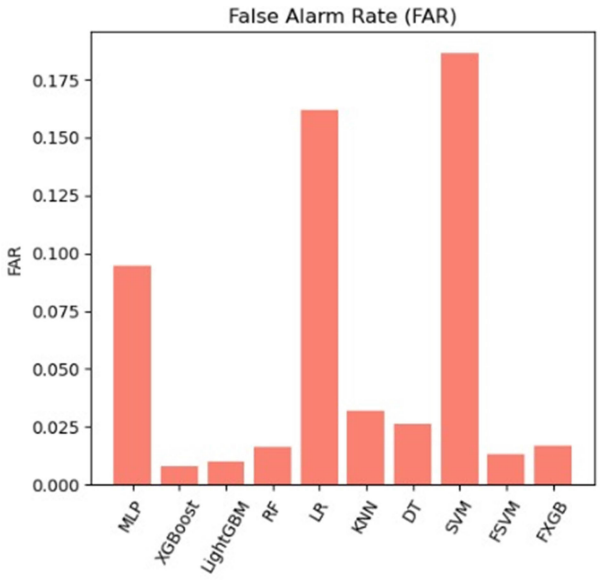


FIGURE 8. False alarm rate comparison of centralized and federated learning Models.

fields, including machine learning and cybersecurity, to quantify the frequency of false positives in any information system. It occurs when the system incorrectly identifies a normal event as an abnormal activity or a threat. A high FAR rate indicates that the system generates too many false alarms, which can lead to reduced efficiency and performance. The figure illustrates that models XGBoost, LGBM, and FSVM have a minimum False Alarm Rate, indicating that these models are more reliable and trusted than others.

Moreover, Figure 9 presents the communication cost of each centralized machine learning model, which has more than 5 MB, however, a very low communication cost is consumed by each Federated model. So, the Federated model is feasible in terms of communication cost.

Figure 10 shows the Receiver Operating Characteristics (ROC) curve of the selected ML models. The ROC curve is a visual representation of the performance effectiveness of a model. It demonstrates the trade-off between the True Positive Rate (TPR) and the False Positive Rate (FPR) across different thresholds. The ROC curve and the Area Under the Curve (AUC) score help to determine how well the model balances sensitivity and specificity. The ideal model attains a TPR of 1 and an FPR of 0, positioning at the top-left corner of the ROC plot. A model with an AUC of 1.0 is considered excellent, while an AUC of 0.5 for a normal model, and an AUC below 0.5 indicates poor performance, and the model may make an incorrect prediction. In the particular case of the cyber risk assessment task, the federated models FSVM and FXGB have a TPR of 1.0 with an FPR of almost 0. Similarly, the centralized ML models, RF, XGBoost, and LGBM have been rated as the best models.

Performance Matrices: The confusion matrix is used to evaluate the performance of ML models. Terms such as True Positive (TP), False Positive (FP), False Negative (FN),

TABLE 6. Security controls.

Security Control	Security Type	Description of actions
Sc-1	Physical Security	The physical security should be monitored by surveillance cameras, IDS sensors, smoke and heat detectors. Additionally, it is essential to ensure that IIoT devices are protected from physical damages.
Sc-2	Device Authentication	Device authentication is required and necessary to avoid the malicious and suspicious activities on any node.
Sc.-3	Secure the end nodes	The end devices such as radio frequency circuit, integrated circuits (ICs), chips, I/O devices etc. must be secured and have high quality.
Sc.-4	Safe Booting	As the end devices have low computing power, hash algorithms and techniques cannot be implemented; therefore, NH and WH cryptographic algorithms are used to optimum solutions [32].
Sc.-5	Integrity of data	To reduce risk of data tampering, each end node should be equipped with an error detection system, such as a parity bit or checksum. Additionally, using a cryptographic hash can further enhance network security[33].
Sc.-6	Anonymity	Attackers can conceal the information such as location, personal identity, etc. and injecting node in the IIoT system. The K-anonymity approach can be utilized to address this issue by ensuring that individual data points are indistinguishable from at least K-1 other data points. [34].
Sc.-7	DoS protection	Several methods are available to prevent and mitigate DoS attacks, including filtering and cleaning traffic from specific IP addresses, limiting the number of packets sent from an individual IP, and forwarding packets from specific IPs directly to their intended targets [35].
Sc.-8	Abnormal activity	Maintaining a log of all unusual or abnormal activities allows the organization to notice the alert when ordinary activities occur take steps to address and control the activity.
Sc.-9	Data encryption	Strong encryption method to avoid a MiTM attack in a client-server environment. When encrypted the important data, the attacker or hacker will not have the ability to read the data.
Sc.-10	Offsite data backups	Offsite data backups are stored off-site may be important in preventing losses and catastrophic incident. This technique also help to prevent the loss of data due to any natural disasters such as earthquakes and floods etc.
Sc.-11	Input sanitization	It prevents codes from being a hazardous and usual effect on database of the IIoT system and also prevents SQL injection.
Sc.-12	Intrusion detection/ prevention	IIDS monitors system behavior and detects malicious actions but does not take immediate or proactive steps to stop intrusions. However, prevention actively take part to prevent any intrusions in the SEMS.
Sc.-13	Confidentiality of data	Confidentiality of data for preventing the illegitimate and unauthorized access in the system.
Sc.-14	data-integrity	It can be maintained and ensured by using cryptographic hash function algorithms which cannot tempered easily.
Sc-15	Secure Routing	Secure routing play important role in safe usage of sensor systems and ensure cyber securty of the system.
Sc-16	Spoofing	It refers to impersonating another entity or device in order to gain unauthorized access. Use strong authentication like mutual TLS (Transport Layer Security) or digital certificates to verify device identities. Encryption is used to ensure data integrity and prevent spoofing.
Sc-17	Inside attack and outside attack	The inside attack may be protected by ad-hoc routing security and outside attack can be secured by authentication and encryption.
Sc-18	Encryption to secure classified information	Different types of encryption can be used to defeat the side channel attack and secure the use case.
Sc-19	Bluetooth security practices	Precautions to protect the Bluetooth are : (1)Turn-off the devices not in use to prevent the device from other Bluejackets attacks. (2) Off the pairing immediately after use. (3) Avoid entering passkeys whenever possible. (4) Regularly update the software and drivers to incorporate the latest product improvements. (5) Pairing the devices as needed. (6)Always use SSP (Secure Simple Pairing) instead of legacy PIN authentication for pairing. (7) Avoid accepting transmissions from suspicious or unknown devices.
Sc-20	Man-in-the-Middle (MiTM)	A combination of keys should be used to protect against Man-in-the-Middle (MiTM) attacks [36].
Sc-21	Eavesdropping	To prevent eavesdropping, always use the encryption link for data transmissions including passive eavesdropping [37].
Sc-22	Enabling encryption	Ensure that encryption is enabled on all links when using multi-hop communication. Otherwise, entire communication chain may be compromised [38].
Sc-23	Mutual authentication	Mutual authentication will provide secure network connections [39].
Sc-24	Broadcast Interceptions	Reduce security risks by encrypting broadcast message[40].
Sc-25	Encryption key size	Always use maximum encryption key size which may protect from brute-force attacks [41].
Sc-26	Bluetooth Safety and security	Security Mode III is ensure stronger protection and authentication for Bluetooth security [42].
Sc-27	GAT Tacker	mitigating Man-in-the-Middle (MiTM) attacks have been proposed to enhance security by identifying suspicious activities and preventing unauthorized interception or alteration of communications[43]
Sc28	Infected Bluetooth device	The proposed method in [44] can enhance and complement existing security measures for systems and services built on Bluetooth Low Energy (BLE).
Sc-29	Confidentiality in LoraWAN Channel	The solution outlined in [45] is recommended as a resolution to the issue
Sc-30	LoRaWAN Spoofing	The solution outlined in [45] is recommended as a resolution to the issue
SC-31	VPN Attack	The solution outlined in [46] is recommended as a resolution to the issue

and True Negative (TN) are used to represent the confusion matrix. The precision metric shows the proportion of labeled units of a model belonging to that class. The metric measures the positive proportion of a model by TP over the combination

TABLE 7. Use Case: Reduction of attack surface.

Vulnerablity Eploxite	Threats/Attacks in SEMS	Security Controls	IoT layer	Use case devices
V-1,V-2, V-3, V-5, V-19, V-20, V-25, V-27, V-28, V-29, V-30, V-31, V-32, V-33, V-34	Denial of service (Theft of sensor), Spoofing (sensor Impersonation of transmitting data), Tempering (Modification of data), DistributedDenial of service (Jamming), DoS (Excessive Sensor Data Generation), DoS (Sensor Battery Depletiony	Sc-1, Sc-2, Sc-3, Sc-4, Sc-5, Sc-8, Sc-7, Sc-8, Sc-10, Sc-12	Physical Layer	Sensors
V-4, V-6, V-7, V-8, V-9, V-10, V-11, V-12, V-13, V-14, V-15, V-16, V-17, V-18, V-21, V-22, V-23, V-24, V-26, V-35, V-36, V-37, V-38, V-39, V-40	Impersonation input data on sensor, Spoofing (on LoRaWAN), Tampering (Data integrity issues), DoS (unauthentic interferencein network), Physical Access (Single Factor Authentication), Attack on VPN system, spoofing by DoS, Exploitation in system code (code injection), elevation of privileges, , Denial Of Service (Jamining attack),	Sc-7, Sc-9, Sc-11,Sc-13, Sc-14, Sc-15, S-16, Sc-17, Sc-18, Sc- 19, Sc-20,Sc-21, Sc-22, Sc-23, Sc-24, Sc-26, Sc-25, Sc-26,Sc-27,Sc-28,Sc-29,Sc-30,Sc-31	Network layer	Gateway, Edge Gateway, Cloud, database

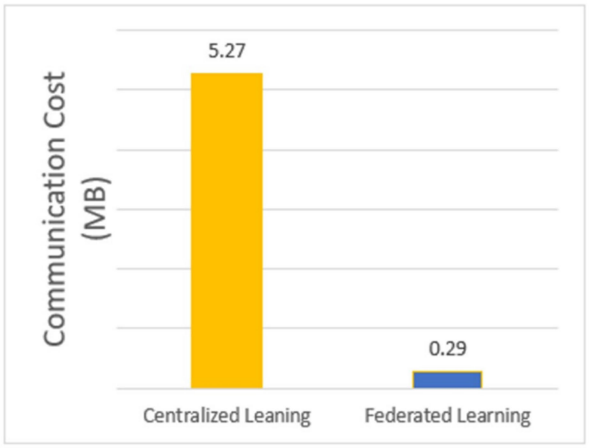


FIGURE 9. Communication cost of centralized and federated learning Models.

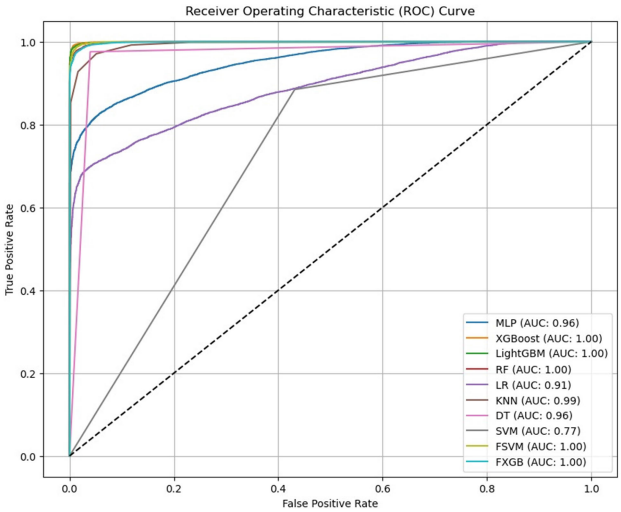


FIGURE 10. Receiver Operating Characteristics (ROC) comparison of centralized and federated learning Models.

of TP and FP, as shown in the following equation.

$$Precision = \frac{TP}{TP + FP} \tag{6}$$

The recall metric calculates the predictive accuracy of a model for a particular class. It measures the positive proportion in a model by TP over the combination of both FP and FN as shown in the following equation.

$$Recall = \frac{TP}{FP + FN} \tag{7}$$

The last performance metric, the F-1 score, quantifies a model between 0-1 by aggregating both the Recall and Precision matrices as shown in the following equation.

$$F1 = 2\frac{Precision.Recall}{Precision + Recall} \tag{8}$$

Table 8 summarizes the Precision, F-1, and Recall metrics selected for centralized and decentralized(Federated) ML models. For decentralized (federated) learning, both FedMLP and Fed XGBoost outperformed for large datasets. However, for centralized machine learning, the MLP outperformed, and the XGboost model able to achieve higher precision and F1-score with a marginal difference.

VI. DISCUSSION AND FUTURE WORK

The CIRA methodology is developed to assess and evaluate possible cybersecurity risks and improve the overall safety and security of the IIoT system. Using the different centralized and distributed (federated)machine learning techniques, results revealed that federated machine learning, like FXGboost and FSVM, can achieve higher accuracy, lower FAR, and lower communication cost with high scalability. The ROC curve also shows that the performance of FSVM and FXGB is up to the mark. On the other hand, the centralized ML models like XGBoost, LightGBM, and Logistic Regression have the capability and performance for accuracy, training time, FAR, and ROC of risk assessment of cybersecurity threats.

In summary, the choice of centralized and distributed machine learning models depends on the specific requirements of the IIoT environment, such as several devices or nodes, the network, the nature, and the context of the task. The centralized ML models, such as SVM and KNN, are preferred for speed and simplicity, DT for interoperability, and

TABLE 8. Performance metrics of various models under Centralized and Federated Learning settings.

Category	Model	Class	Precision	Recall	F1-Score
Centralized Learning	MLP	Low	1.00	0.99	0.99
		Medium	0.99	0.99	0.99
		High	0.98	0.98	0.98
	XGBoost	Low	0.99	0.98	0.99
		Medium	0.97	0.97	0.96
		High	0.95	0.96	0.95
	LightGBM	Low	0.95	0.96	0.95
		Medium	0.93	0.93	0.95
		High	0.93	0.93	0.95
	Random Forest	Low	0.95	0.92	0.94
		Medium	0.95	0.93	0.94
		High	0.92	0.95	0.97
	Logistic Regression	Low	0.95	0.92	0.94
		Medium	0.90	0.94	0.95
		High	0.91	0.95	0.95
Federated Learning	Federated SVM	Low	0.99	0.99	0.99
		Medium	0.99	1.00	1.00
		High	1.00	1.00	1.00
	Federated XGBoost	Low	0.99	0.99	0.99
		Medium	0.99	0.99	0.99
		High	0.99	1.00	1.00

federated ML models like FXboost and FSVM for accuracy, safety, and scalability. These trade-offs and comparisons of the models allow practitioners to select the most appropriate algorithm for their specific needs, balancing between safety, scalability, interoperability, performance, and computational cost.

CIRA deployment in IIoT environments demands strategic planning to ensure optimal performance, robust integration with systems like ICS, SCADA, and IoT gateways, and strict adherence to industry standards such as NIST and IEC 62443.

Computational Requirements for CIRA Deployment:

- **Processing Power:** Depending on whether traditional ML or Federated Learning is used, CIRA may require GPU/TPU acceleration for training complex models.
- **Storage and Bandwidth:** Handling vast IIoT sensor data requires efficient data compression and distributed storage solutions.
- **Energy Efficiency:** Optimizing model inference for low-power IIoT devices is critical to maintaining real-time performance.
- **Scalability Considerations**: (i). Horizontal Scalability: CIRA should support distributed and federated learning architectures to scale across multiple IIoT nodes. (ii) Adaptive Learning: The model must continuously adapt to new threats using incremental learning techniques. and (iii) Load Balancing: Efficient resource allocation ensures the system remains operational even under high network traffic conditions.

These factors collectively ensure that CIRA remains accurate, adaptive, and resilient in securing IIoT infrastructures. In the future, the focus will be on the integration of digital twin technology with blockchain-based smart contracts to enhance cybersecurity risk management.

VII. CONCLUSION

This paper proposed CIRA methodology, a novel approach to providing an intelligent cybersecurity risk assessment model to overcome the cybersecurity issues of Industrial IoT before exploiting the system. The risk assessment process of the proposed methodology consists of four phases. The analytical scope contains a declaration of assets, vulnerability assessment, and associated cybersecurity threats using the STRIDE threat model in the first phase. Data processing, deployment of machine learning algorithms for risk evaluation, and predictions of possible cybersecurity attacks in the second phase. In the third phase, results and reporting of potential cyber risks. In the last phase, propose mitigation strategies and apply security controls against each cyber threat. A use case on a smart energy management system (SEMS) is presented for easy understanding of the proposed methodology. A detailed risk level calculation of the use case, including asset type, vulnerability, CIA traits, risk score, exploitability, likelihood, and risk level. A synthetic data set is used to validate the algorithm on different distributed (federated) and centralized machine learning models. To determine the best and optimal model for cyber risk assessment, use different federated and centralized ML techniques in different parameters like prediction accuracy, training time, communication cost, false alarm rate, and ROC curve. The results and performance metrics revealed that decentralized (federated) machine learning models outperformed for prediction accuracy by 98 %, lower communication cost by 0.29 MB, lower False Alarm Rate

(FAR), and best ROC curve value. However, the centralized machine models, such as XGBoost, RF, and MLP, have 99 % prediction accuracy and a lower false alarm rate, and optimally perform on the ROC curve. The performance of the models is evaluated with the state-of-the-art matrices such as precision, recall, and F1-score, showing that the Federated machine learning techniques are feasible for medium to large datasets with safety, security, and scalability of IIoT nodes. The centralized ML techniques are effective and perform well on small to medium datasets with low training time and low false alarm rate. In a real-time IIoT environment, deployment of this FL-based model can significantly enhance system security by sensitizing the security threats and vulnerabilities. The proposed methodology not only enhances the security and scalability of smart industries but also fosters new research avenues for researchers in the field of Industry 4.0.

CONFLICT OF INTEREST

The authors declare that they have no conflict of interest, and all of they agree to publish this article under academic ethics.

AUTHOR CONTRIBUTIONS

All the authors contributed equally to the manuscript.

REFERENCES

[1] P. Anand, Y. Singh, A. Selwal, M. Alazab, S. Tanwar, and N. Kumar, "IoT vulnerability assessment for sustainable computing: Threats, current solutions, and open challenges," *IEEE Access*, vol. 8, pp. 168825–168853, 2020.

[2] G. Abbas, A. Mehmood, M. Carsten, G. Epiphaniou, and J. Lloret, "Safety, security, and privacy in machine learning-based Internet of Things," *J. Sensor Actuator Netw.*, vol. 11, p. 38, Jul. 2022.

[3] J. Shehu Yalli, M. Hilmi Hasan, and A. Abubakar Badawi, "Internet of Things (IoT): Origins, embedded technologies, smart applications, and its growth in the last decade," *IEEE Access*, vol. 12, pp. 91357–91382, 2024.

[4] R. Alanazi and A. Aljuhani, "Anomaly detection for industrial Internet of Things cyberattacks," *Comput. Syst. Sci. Eng.*, vol. 44, no. 3, pp. 2361–2378, 2023.

[5] H. Razavi and M. R. Jamali, "Large language models (LLM) for estimating the cost of cyber-attacks," in *Proc. 11th Int. Symp. Telecommun. (IST)*, Oct. 2024, pp. 403–409.

[6] C. A. Gabrian, "Impact zones: How cybercrime disrupts and shapes the landscape of data security," in *Proc. Int. Conf. Mach. Intell. Secur. Smart Cities (TRUST)*, vol. 1, Jul. 2024, pp. 59–68.

[7] Kaspersky. (Mar. 1, 2022). *Pushing The Limits: How to Address Specific Cybersecurity Demands and Protect IoT*. Kaspersky Press Releases. [Online]. Available: https://www.kaspersky.com/about/press-releases/43-of-businesses-dont-protect-their-full-iot-suite

[8] T. AlSalem, M. Almaiah, and A. Lutfi, "Cybersecurity risk analysis in the IoT: A systematic review," *Electronics*, vol. 12, no. 18, p. 3958, Sep. 2023.

[9] P. Subhash, M. O. H. A. M. M. E. D. Qayyum, K. Mehernadh, K. J. Sahit, C. L. Varsha, and M. N. Hardeep, "Risk assessment threat modelling using an integrated framework to enhance security," *J. Theor. Appl. Inf. Technol.*, vol. 102, pp. 3857–3867, May 2024.

[10] M. Sahinoglu, "Cyber security risk assessment and optimal risk management of a national vulnerability database," *Int. J. Comput. Theory Eng.*, vol. 16, no. 4, pp. 104–126, 2024.

[11] R. Singla, N. Reddy, R. Bettati, and H. Alnuweiri, "Toward a multidimensional analysis of the national vulnerability database," *IEEE Access*, vol. 11, pp. 93354–93367, 2023.

[12] V. T.-T. Vo, T.-H. Shin, H.-J. Yang, S.-R. Kang, and S.-H. Kim, "A comparison between centralized and asynchronous federated learning approaches for survival outcome prediction using clinical and PET data from non-small cell lung cancer patients," *Comput. Methods Programs Biomed.*, vol. 248, May 2024, Art. no. 108104.

[13] M. Kalinin, V. Krundyshev, and P. Zegzhda, "Cybersecurity risk assessment in smart city infrastructures," *Machines*, vol. 9, no. 4, p. 78, Apr. 2021, doi: 10.3390/machines9040078.

[14] M. Flores, D. Heredia, R. Andrade, and M. Ibrahim, "Smart home IoT network risk assessment using Bayesian networks," *Entropy*, vol. 24, no. 5, p. 668, May 2022.

[15] T. Kieras, M. J. Farooq, and Q. Zhu, "RIoTS: Risk analysis of IoT supply chain threats," in *Proc. IEEE 6th World Forum Internet Things (WF-IoT)*, Jun. 2020, pp. 1–6, doi: 10.1109/WF-IoT48130.2020.9221323.

[16] K. Kandasamy, S. Srinivas, K. Achuthan, and V. P. Rangan, "IoT cyber risk: A holistic analysis of cyber risk assessment frameworks, risk vectors, and risk ranking process," *EURASIP J. Inf. Secur.*, vol. 2020, no. 1, pp. 1–18, Dec. 2020, doi: 10.1186/s13635-020-00111-0.

[17] G. George and S. M. Thampi, "Combinatorial analysis for securing IoT-assisted industry 4.0 applications from vulnerability-based attacks," *IEEE Trans. Ind. Informat.*, vol. 18, no. 1, pp. 3–15, Jan. 2022.

[18] F. Arat and S. Akleylek, "Attack path detection for IIoT enabled cyber physical systems: Revisited," *Comput. Secur.*, vol. 128, May 2023, Art. no. 103174.

[19] W. Abbass, Z. Bakraouy, A. Baina, and M. Bellafkih, "Classifying IoT security risks using deep learning algorithms," in *Proc. 6th Int. Conf. Wireless Netw. Mobile Commun. (WINCOM)*, Oct. 2018, pp. 1–6.

[20] G. George and S. M. Thampi, "Vulnerability-based risk assessment and mitigation strategies for edge devices in the Internet of Things," *Pervas. Mobile Comput.*, vol. 59, Oct. 2019, Art. no. 101068.

[21] H. Razavi, M. R. Jamali, M. Emsaki, A. Ahmadi, and M. Hajiaghei-Keshteli, "Quantifying the financial impact of cyber security attacks on banks: A big data analytics approach," in *Proc. IEEE Can. Conf. Electr. Comput. Eng. (CCECE)*, Sep. 2023, pp. 533–538.

[22] A. Ur-Rehman, I. Gondal, J. Kamruzzaman, and A. Jolfaei, "Vulnerability modelling for hybrid industrial control system networks," *J. Grid Comput.*, vol. 18, no. 4, pp. 863–878, Dec. 2020.

[23] J. S. Yuen, K. L. Choy, H. Y. Lam, and Y. P. Tsang, "An intelligent risk management model for achieving smart manufacturing on the Internet of Things," in *Proc. Portland Int. Conf. Manage. Eng. Technol. (PICMET)*, Aug. 2019, pp. 1–8.

[24] K. Raghunandan, "Supervisory control and data acquisition (SCADA)," in *Introduction toWireless Communications and Networks: A Practical Perspective*. Cham, Switzerland: Springer, 2022, pp. 321–337.

[25] R. Sasaki, "Reconsideration of risk communication and risk assessment support methods for security," in *Proc. IEEE 23rd Int. Conf. Softw. Qual., Rel., Secur. Companion (QRS-C)*, Oct. 2023, pp. 516–523.

[26] S. Ksibi, F. Jaidi, and A. Bouhoula, "A comprehensive study of security and cyber-security risk management within e-Health systems: Synthesis, analysis and a novel quantified approach," *Mobile Netw. Appl.*, vol. 28, no. 1, pp. 107–127, Feb. 2023.

[27] A. Mehmood, G. Epiphaniou, C. Maple, N. Ersotelos, and R. Wiseman, "A hybrid methodology to assess cyber resilience of IoT in energy management and connected sites," *Sensors*, vol. 23, no. 21, p. 8720, Oct. 2023.

[28] P. Chhotaray, B. C. Behera, B. R. Moharana, K. Muduli, and F.-T.-R. Sephyrin, "Enhancement of manufacturing sector performance with the application of industrial Internet of Things (IIoT)," in *Smart Technologies for Improved Performance of Manufacturing Systems and Services*. Boca Raton, FL, USA: CRC Press, 2024, pp. 1–19.

[29] O. Saßnick, T. Rosenstatter, C. Schäfer, and S. Huber, "STRIDE-based methodologies for threat modeling of industrial control systems: A review," in *Proc. IEEE 7th Int. Conf. Ind. Cyber-Phys. Syst. (ICPS)*, May 2024, pp. 1–8.

[30] M. F. Franco, E. Sula, A. Huertas, E. J. Scheid, L. Z. Granville, and B. Stiller, "SecRiskAI: A machine learning-based approach for cybersecurity risk prediction in businesses," in *Proc. IEEE 24th Conf. Bus. Informat. (CBI)*, vol. 1, Jun. 2022, pp. 1–10.

[31] L. Mariot, S. Picek, D. Jakobovic, and A. Leporati, "Evolutionary algorithms for designing reversible cellular automata," *Genetic Program. Evolvable Mach.*, vol. 22, no. 4, pp. 429–461, Dec. 2021.

[32] S. Windarta, S. Suryadi, K. Ramli, B. Pranggono, and T. S. Gunawan, "Lightweight cryptographic hash functions: Design trends, comparative study, and future directions," *IEEE Access*, vol. 10, pp. 82272–82294, 2022.

[33] Y. Liang and R. Samavi, "Optimization-based k-anonymity algorithms," *Comput. Secur.*, vol. 93, Jun. 2020, Art. no. 101753.
[34] M. Korczyński, Y. Nosyk, Q. Lone, M. Skwarek, B. Jonglez, and A. Duda, "Don't forget to lock the front door! inferring the deployment of source address validation of inbound traffic," in *Proc. Int. Conf. Passive Act. Netw. Meas.*, Cham, Switzerland: Springer, Mar. 2020, pp. 107–121.
[35] M. Thankappan, H. Rifà-Pous, and C. Garrigues, "Multi-channel man-in-the-middle attacks against protected Wi-Fi networks: A state of the art review," *Expert Syst. Appl.*, vol. 210, Dec. 2022, Art. no. 118401.
[36] S. A. Haider, M. N. Adil, and M. Zhao, "Optimization of secure wireless communications for IoT networks in the presence of eavesdroppers," *Comput. Commun.*, vol. 154, pp. 119–128, Mar. 2020.
[37] S. Singh, P. K. Sharma, S. Y. Moon, and J. H. Park, "Advanced lightweight encryption algorithms for IoT devices: Survey, challenges and solutions," *J. Ambient Intell. Humanized Comput.*, vol. 15, no. 2, pp. 1625–1642, May 2017.
[38] R. Melki, H. N. Noura, and A. Chehab, "Lightweight multi-factor mutual authentication protocol for IoT devices," *Int. J. Inf. Secur.*, vol. 19, no. 6, pp. 679–694, Dec. 2020.
[39] A. Diro, H. Reda, N. Chilamkurti, A. Mahmood, N. Zaman, and Y. Nam, "Lightweight authenticated-encryption scheme for Internet of Things based on publish-subscribe communication," *IEEE Access*, vol. 8, pp. 60539–60551, 2020.
[40] P. Wichmann, M. Marx, H. Federrath, and M. Fischer, "Detection of brute-force attacks in end-to-end encrypted network traffic," in *Proc. 16th Int. Conf. Availability, Rel. Secur.*, Aug. 2021, pp. 1–9.
[41] A. Lacava, V. Zottola, A. Bonaldo, F. Cuomo, and S. Basagni, "Securing Bluetooth low energy networking: An overview of security procedures and threats," *Comput. Netw.*, vol. 211, Jul. 2022, Art. no. 108953.
[42] U. O. Obonna, F. K. Opara, C. C. Mbaocha, J.-K.-C. Obichere, I. O. Akwukwaegbu, M. M. Amaefule, and C. I. Nwakanma, "Detection of man-in-the-middle (MitM) cyber-attacks in oil and gas process control networks using machine learning algorithms," *Future Internet*, vol. 15, no. 8, p. 280, Aug. 2023.
[43] J. Yang, C. Poellabauer, P. Mitra, and C. Neubecker, "Beyond beaconing: Emerging applications and challenges of BLE," *Ad Hoc Netw.*, vol. 97, Feb. 2020, Art. no. 102015.
[44] R. Janakiraman, M. Waldvogel, and Q. Zhang, "Indra: A peer-to-peer approach to network intrusion detection and prevention," in *Proc. WET ICE 12th IEEE Int. Workshops Enabling Technol., Infrastruct. Collaborative Enterprises*, Jun. 2003, pp. 226–231, doi: 10.1109/ENABL.2003.1231412.
[45] E. Hodo, X. Bellekens, A. Hamilton, P.-L. Dubouilh, E. Iorkyase, C. Tachtatzis, and R. Atkinson, "Threat analysis of IoT networks using artificial neural network intrusion detection system," in *Proc. Int. Symp. Netw., Comput. Commun. (ISNCC)*, May 2016, pp. 1–6, doi: 10.1109/ISNCC.2016.7746067.
[46] G. Abbas, A. Mehmood, J. Lloret, M. S. Raza, and M. Ibrahim, "FIPA-based reference architecture for efficient discovery and selection of appropriate cloud service using cloud ontology," *Int. J. Commun. Syst.*, vol. 33, no. 14, Sep. 2020, Art. no. e4504.
[47] M. F. Ogundipe and X. Shi, "Detecting cyber threats and enhancing security in IoT devices: A federated learning approach," in *Proc. Int. Conf. Global Aeronaut. Eng. Satell. Technol. (GAST)*, Apr. 2024, pp. 1–6.



GHULAM ABBAS is currently a Ph.D. Scholar with Hazara University, Mansehra, Pakistan. He is working on advanced methods for improving cybersecurity, data analytics, and intelligent systems in industrial applications. His work focuses on integrating machine learning models to enhance the functionality and security of IoT-based systems. He is actively involved in exploring innovative solutions for challenges in the intersection of industry and emerging technologies. His research interests include cyber intelligence, cybersecurity risk management, machine learning, and the Industrial Internet of Things (IoT).



MUSHTAQ ALI received the Ph.D. degree in computer science from the University of Electronic Science and Technology of China, from 2012 to 2015. He is currently an Associate Professor with Hazara University, Mansehra, Pakistan. He is an HEC-Approved Ph.D. Supervisor. He has contributed significantly to advancements in AI and image processing technologies, focusing on innovative solutions for healthcare and multimedia applications. His research interests include digital image processing, computer vision, artificial intelligence (AI), medical image analysis, and multimedia retrieval systems.



MUNEER AHMAD (Senior Member, IEEE) is currently a Senior Lecturer with the University of Roehampton, London. He has led more than 15 AI projects, secured substantial research funding, and published more than 100 articles in leading journals, including IEEE TRANSACTIONS ON INTELLIGENT TRANSPORTATION SYSTEMS, *Cancers*, and *Scientific Reports*. He has supervised more than 50 scholars across bachelor's, master's, and Ph.D. levels. His research interests include artificial intelligence, machine learning, and their multidisciplinary applications, particularly in the Internet of Things (IoT) and the Industrial IoT (IIoT) systems.



AJMAL KHAN is currently an Associate Researcher with the Communication and Information Research Center (CIRC), Sultan Qaboos University, Oman. He has contributed significantly to enhancing the efficiency and security of communication networks, particularly in intelligent transportation and IoT environments. His research interests include vehicular ad hoc networks (VANETs), machine learning applications, artificial intelligence in the Internet of Things (AIoT), and disaster management systems.